



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI•

Technische Richtlinie TR-03174: Sichere Anwendungen im Finanzwesen

Teil 2: Web-Anwendungen

Version 4.0



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	18.05.2022	Referat DI 24	Erste Version
2.0	25.03.2024	Referat DI 24	Überarbeitung Einleitung Überarbeitung Kapitel 3 Überarbeitung Kapitel 4
3.0	16.09.2024	Referat D24	Finalisierung
4.0	01.06.2026	Referat D24	Ganzheitliche Überarbeitung der TR, Inhalt und Struktur

Inhalt

1	Einleitung.....	5
1.1	Gegenstand und Zielsetzung der Technischen Richtlinie.....	5
1.2	Übersicht der Technischen Richtlinie	5
1.2.1	Aufbau.....	5
1.2.2	Begriffe	5
2	Überblick der Anwendungen im Finanzwesen.....	6
2.1	Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1)	6
2.1.1	Native-Anwendungen.....	6
2.1.2	Hybride Ansätze.....	6
2.2	Web-Anwendungen (TR-03174, Teil 2, dieses Dokument).....	6
2.3	Hintergrundsysteme (TR-03174, Teil 3).....	7
2.3.1	Selbst und extern gehostete Systeme.....	7
2.3.2	Cloud Computing.....	7
3	Security Problem Definition	8
3.1.1	Annahmen	8
3.1.2	Bedrohungen	8
3.1.3	Organisatorische Sicherheitspolitiken.....	9
3.1.4	Restrisiken.....	10
4	Empfehlungen.....	11
4.1	Anwendungszweck.....	11
4.2	Architektur.....	11
4.3	Quellcode.....	12
4.4	Drittanbieter-Software	13
4.5	Kryptographische Umsetzung.....	14
4.6	Authentisierung und Authentifizierung	14
4.7	Datensicherheit.....	16
4.8	Netzwerkkommunikation.....	16
4.9	Plattformspezifische Interaktion.....	17
5	Anforderungen an die Prüfung.....	18
5.1	Protokollierung der Prüfungsergebnisse	18
5.2	Risikoanalyse und -bewertung.....	19
	Anhang A: Schutzbedarf sensibler Datenelemente.....	21
	Anhang B: Prüftabellen.....	22
	Abkürzungsverzeichnis.....	23
	Literaturverzeichnis	24

Tabellenverzeichnis

Tabelle 1: Begriffe der Technischen Richtlinie.....	5
Tabelle 2: Anwendungszweck	11
Tabelle 3: Architektur	11
Tabelle 4: Quellcode.....	12
Tabelle 5: Drittanbieter-Software	13
Tabelle 6: Kryptographische Umsetzung.....	14
Tabelle 7: Authentisierung und Authentifizierung	14
Tabelle 8: Datensicherheit.....	16
Tabelle 9: Netzwerkkommunikation.....	16
Tabelle 10: Plattformspezifische Interaktion.....	17
Tabelle 11: Prüftiefen und Mindestanforderungen.....	18
Tabelle 12: Mögliche Prüfergebnisse	19
Tabelle 13: Anforderung anhand der Daten-Kritikalität.....	20
Tabelle 14: Schutzbedarf sensibler Datenelemente.....	21
Tabelle 15: Abkürzungsverzeichnis.....	23

1 Einleitung

1.1 Gegenstand und Zielsetzung der Technischen Richtlinie

Das Bundesamt für Sicherheit in der Informationstechnik [BSI] verfügt mit den IT-Grundschutzbausteinen und diversen Technischen Richtlinien [TR] über Umsetzungshilfen, um Anwendungen und IT-Infrastrukturen nach dem Stand der Technik abzusichern. Die vorliegende TR soll bei der Erstellung von Web-Anwendungen im Finanzumfeld mit einer kompakten Übersicht möglicher technischer Maßnahmen zur Informationssicherheit unterstützen. Die TR richtet sich vor allem an einen nicht regulierten, heterogenen Adressatenkreis von Entwicklern und Anbietern mobiler Anwendungen, Web-Anwendungen und deren Hintergrundsysteme im finanznahen Umfeld, beispielsweise digitale Haushalts- und Kassenbücher, Steuer-, Finanz- und Kreditrechner sowie Apps mit Bezahlungsfunktion von Discountern.

Die Hinweise und Empfehlungen der TR stellen keine regulatorischen Pflichten dar. Für Finanzunternehmen, die einer Regulierung unterliegen, kann diese TR als eine Orientierungshilfe bei der Umsetzung der regulatorischen Vorgaben dienen. Europäische (z.B. [PSD2], [DORA], etc.) und / oder nationale Vorgaben (z.B. Rundschreiben der Bundesanstalt für Finanzdienstleistungsaufsicht [BaFin]) haben Vorrang vor den Empfehlungen der TR. Die alleinige Umsetzung der TR entbindet daher nicht von der zusätzlichen, weiterführenden Auseinandersetzung mit regulatorischen und weiteren technischen Vorgaben.

1.2 Übersicht der Technischen Richtlinie

1.2.1 Aufbau

Anwendungen im Sinne dieser TR sind Web-Anwendungen im Finanzwesen, entsprechend der Definition in Kapitel 2. Kapitel 3 zeigt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken auf, welche als Hintergrundinformation für die weitere Anwendung der TR dienen. In Kapitel 4 werden die Anforderungen an eine Web-Anwendung aufgelistet, Kapitel 5 zeigt das Vorgehen der Überprüfung der Umsetzung dieser Anforderungen auf. Anhang A gibt Beispiele für den Schutzbedarf, welcher zur Risikobewertung existenziell ist. Die Tabellen der Anlage B können unterstützend bei der Überprüfung bzw. Auditierung genutzt werden.

1.2.2 Begriffe

Diese TR verwendet folgende Begriffe:

Tabelle 1: Begriffe der Technischen Richtlinie

Begriff	Beschreibung
MUSS	Die Anwendung muss eine bestimmte Eigenschaft zwingend aufweisen.
DARF NICHT / DARF KEIN(E)	Die Anwendung darf eine bestimmte Eigenschaft unter keinen Umständen aufweisen.
SOLL	Die Anwendung muss eine bestimmte Eigenschaft aufweisen, außer es wird dargelegt, dass durch ein Nicht-Umsetzen kein Risiko für den sicheren Betrieb besteht, bzw. eine Umsetzung, aufgrund von technischen Einschränkungen, derzeit nicht möglich ist.
KANN	Die Anwendung kann eine bestimmte Eigenschaft aufweisen, wobei ein Umsetzen dieser Eigenschaft vom Lösungsanbieter anzuzeigen ist.

2 Überblick der Anwendungen im Finanzwesen

2.1 Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1)

Der Begriff „mobile Anwendung“ bezeichnet ein Programm, das auf einer mobilen Plattform ausgeführt wird. Grundsätzlich lassen sich solche Anwendungen in drei Kategorien unterteilen:

1. Native Anwendungen, zugeschnitten auf die Plattform, auf der sie ausgeführt werden,
2. Web-Anwendungen, plattformunabhängige Implementierung, laufen im Web-Browsers,
3. Hybride Ansätze, Kombinationen aus nativen Anwendungen und Web-Anwendungen.

Da mobile Anwendungen weit über den Einsatz von Web-Anwendungen in mobilen Browsern oder hybriden Anwendungen hinausgehen, liegt der Fokus dieser TR allein auf Web-Anwendungen und dem Web-Teil von hybriden Ansätzen (Absicherung native Anwendungen siehe Teil 1 der TR-03174[TR03174-1]).

2.1.1 Native-Anwendungen

Eine native Anwendung ist passend auf eine Plattform und deren Betriebssystem (beispielsweise Android oder [iOS]) zugeschnitten. Sie basiert auf den bereitgestellten Programmierwerkzeugen (Software Development Kits [SDK]). Diese ermöglichen einen direkten Zugriff auf Gerätekomponenten, wie beispielsweise [GPS], Kamera oder Mikrofon. Aufgrund ihrer Nähe zum Betriebssystem können sie eine gute Performanz, hohe Zuverlässigkeit und intuitive Bedienbarkeit erreichen. Die Anwendungen werden beispielsweise über den plattformeigenen [App]-Store installiert und können oft auch offline betrieben werden. Die Nähe zum Betriebssystem ist auch mit Nachteilen verbunden. Änderungen am Betriebssystem, beispielsweise durch Updates, können dazu führen, dass Anpassungen an der Anwendung vorgenommen werden müssen. Darüber hinaus ist es nicht möglich sie auf anderen Betriebssystemen zu installieren.

2.1.2 Hybride Ansätze

Hybride Anwendungen verbinden sowohl die Vor-, als auch die Nachteile von nativen Anwendungen und Web-Anwendungen. Mit Hilfe des SDKs wird eine Art „Rahmen-Anwendung“ geschaffen. Sie kann auf Gerätekomponenten zugreifen und über einen App-Store bezogen, jedoch nicht auf anderen Plattformen installiert werden, ohne Anpassungen am Quellcode vorzunehmen. Darüber hinaus beinhalten die Rahmen-Anwendungen einen eingebetteten Web-Browser, mit dessen Hilfe Web-Anwendungen in native Anwendungen eingebunden werden können. Dadurch ist es auch Web-Anwendungen möglich, auf die sonst nur den nativen Anwendungen vorbehaltenen Gerätekomponenten zuzugreifen. Allerdings müssen dabei Einbußen bei der Performanz und Stabilität in Kauf genommen werden.

2.2 Web-Anwendungen (TR-03174, Teil 2, dieses Dokument)

Web-Anwendungen sind Anwendungsprogramme, meist Webseiten, die in Kombination mit einem Hintergrundsystem (Kapitel 2.3) ohne Installation auf einem lokalen System betrieben werden können. Solche Webseiten sind oft so programmiert, dass sie wie eine native Anwendung für klassische Desktop-Systeme oder mobile Endgeräte aussehen und sich vergleichbar verhalten. Im Gegensatz zu nativen Anwendungen basieren sie nicht auf einem SDK der zugrundeliegenden Plattformen, sondern auf klassischen Programmierwerkzeugen der Web-Entwicklung. In den meisten Fällen kommen HTML5 und JavaScript zum Einsatz. Aus diesem Grund ist mit ihnen nur ein sehr eingeschränkter Zugriff auf Gerätekomponenten möglich. Ihr größter Vorteil besteht darin, dass sie unabhängig vom Betriebssystem sind. Da die Anwendungen innerhalb eines Web-Browsers laufen, können sie auf jeder Plattform gleichermaßen eingesetzt werden, ohne Anpassungen an der Codebasis vornehmen zu müssen.

2.3 Hintergrundsysteme (TR-03174, Teil 3)

Viele Anwendungen lagern die Verarbeitung und Speicherung von Daten auf ein Server-System (Hintergrundsysteme oder Backend-Services) aus. Darüber hinaus übernehmen diese Systeme oft Aufgaben zur Authentifizierung und Autorisierung von Nutzern oder andere zentrale Tätigkeiten. Dies erlaubt es, dass nicht alle Funktionalitäten der Anwendungen auf den Endgeräten umgesetzt werden müssen. Die Ausprägungen können variieren. Daher ist bei vollumfänglicher sicherheitstechnischer Betrachtung der gesamten Anwendung die Sicherheit des Hintergrundsystems essentiell. Für die Nutzung von Anwendungen, die an ein Hintergrundsystem angeschlossen sind, ist meistens eine aktive Internetverbindung zwingend erforderlich. Dabei wird für die Kommunikation zwischen Front- und Backend-Systemen häufig eine über [TLS] gesicherte Transportverbindung eingesetzt.

Der Einsatz von Hintergrundsystemen wird im wesentlichen in drei Szenarien unterschieden:

1. Der Anbieter der Anwendung verwaltet das Hintergrundsystem selbst.
2. Der Anbieter lässt das Hintergrundsystem von einem Dienstleister verwalten.
3. Das gesamte Hintergrundsystem wird bei einem Cloud-Dienstleister gehostet.

Eine Trennung zwischen Web-Anwendung und Hintergrundsystem ist aufgrund der Abhängigkeiten kaum möglich. Daher muss bei einer solchen Architektur zusätzlich die TR-03174 „Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“ [TR03174-3] beachtet werden.

2.3.1 Selbst und extern gehostete Systeme

Bei selbst gehosteten Systemen agiert der Entwickler des Hintergrundsystems als Betreiber. Damit hat er den direkten Zugriff auf die Systeme. Die Server, auf denen das Hintergrundsystem betrieben wird, sind innerhalb der Betriebsumgebung des Herstellers untergebracht und die physische, technische und organisatorische Absicherung der Systeme erfolgt durch ihn alleine. Der Vorteil dieser Lösung besteht darin, dass der Hersteller alleine und unverzüglich auf jegliche Vorgänge reagieren kann. Da er die Systeme selber verwaltet und die Softwarekomponenten selber auswählt bzw. entwickelt, hat er am meisten Wissen über die mögliche Verwundbarkeit der Systeme. Allerdings lastet in diesem Fall auch die alleinige Verantwortung auf dem Hersteller, sodass er z.B. dauerhaft Personal abstellen muss, um Sicherheitsvorfälle zu überwachen.

Bei extern gehosteten Systemen werden die Server in einem Datacenter eines externen Dienstleisters gehostet. Die Vorteile bei dieser Lösung bestehen darin, dass der Dienstleister in der Regel mehr Erfahrung mit dem Betrieb solcher Systeme hat. Je nach Ausgestaltung übernimmt der externe Hoster auch weitergehende Aufgaben, wie z.B. die Versorgung der Betriebssysteme mit Sicherheitsupdates, Datensicherung und Backups, sowie Überwachung und Monitoring. Der Betreiber muss dem Hoster ein gewisses Maß an Vertrauen entgegenbringen, ihn aber auch steuern und überwachen. So kann er selber z.B. die Integrität der Hardware nicht überwachen. Der Hoster muss darauf achten, dass die Daten der einzelnen Kunden und Systeme voneinander separiert sind. Durch die Aufteilung der Zuständigkeiten können zeitkritische Reibungsverluste entstehen.

2.3.2 Cloud Computing

Cloud Computing beschreibt ein Modell, das bei Bedarf zeitnah und mit wenig Aufwand geteilte Computerressourcen als Dienstleistung, etwa in Form von Servern, Datenspeicher oder Anwendungen, bereitstellt. Je nach Bedarf können Ressourcen flexibel angepasst werden. Dadurch hat der Hersteller der Anwendung weniger Einfluss auf die Ausführungsumgebung als bei einem einfachen Hosting. Das BSI empfiehlt beim Einsatz von Cloud Computing für Anwendungen im Sinne der TR auf Anbieter zurückzugreifen, welche die Anforderungen aus dem „Kriterienkatalog Cloud Computing“ des BSI [KCC-C5] erfüllen. Alternativ sind Anbieter mit vergleichbaren Testaten oder Zertifikaten zulässig (vgl. [TR03174-3]).

3 Security Problem Definition

Die Security Problem Definition beschreibt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken, die für Web-Anwendungen im Finanzwesen zur Erbringung der Sicherheitsleistung relevant sind. Diese müssen nicht abschließend sein und können nach den individuellen Anforderungen ergänzt werden.

3.1.1 Annahmen

A.Backend	Das Hintergrundsystem befindet sich in einer geschützten Umgebung. Es ist durch organisatorische und technische Maßnahmen sichergestellt, dass Angreifer sich keinen physischen Zugriff auf die Infrastruktur des Hintergrundsystems verschaffen können. Das Hintergrundsystem erfüllt die Anforderungen der „TR-03174 Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“ [TR03174-3].
A.Browser	Der durch den Benutzer verwendete Web-Browser ist frei von Schwachstellen. Damit wird angenommen, dass ein Zugriff auf ungeschützte Datenstrukturen im Speicher, welche etwa den Zugriff auf Schlüssel und sensible Daten ermöglicht, ausgeschlossen ist. Der Browser implementiert das TLS-Protokoll zur Absicherung der Kommunikation mit dem Hintergrundsystem entsprechend dem aktuellen Stand der Technik auf sichere Art und Weise. Dies schließt eine korrekte und vollständige Zertifikatsprüfung mit ein.
A.Device	Die Plattform, auf der die Web-Anwendung genutzt wird, wird vom Nutzer selbst betrieben und ist vor Schwachstellen geschützt.
A.DevRNG	Es wird angenommen, dass der Web-Browser des Nutzers für die gesicherte Verbindungsaufnahme zum Hintergrundsystem Zufall ausreichender Qualität benutzt, sodass die Vertraulichkeit und Integrität der übertragenen Daten gesichert sind.
A.Updates	Die Plattform bestehend aus Betriebssystem und Web-Browser, auf der die Web-Anwendung genutzt wird, wird vom Nutzer selbst betrieben und vor Schwachstellen geschützt, etwa durch Aktualisieren des Betriebssystems und des Web-Browsers nach Bereitstellung von Updates. Ihre Sicherheit wurde nicht vorsätzlich durch den Nutzer beeinträchtigt (z.B. „Roots“ oder „Jailbreaks“ ¹). Der Bezug des genutzten Web-Browsers erfolgt ausschließlich über offizielle und vertrauenswürdige Quellen.
A.User	Der Benutzer der Web-Anwendung prüft im Browser, ob er mit der korrekten Internetadresse verbunden ist. Der Nutzer verwendet die standardmäßigen Sicherheitseinstellungen des genutzten Web-Browsers.

3.1.2 Bedrohungen

T.SensitiveData	Sensible Daten in der TR sind im Sinne des Anhang A zu verstehen. Ein Unbefugter erhält Zugriff auf solche sensiblen Daten der Web-Anwendung, etwa auf unverschlüsselt gespeicherte Daten im Dateisystem (z.B. Browsercache) oder Arbeitsspeicher. Dies umfasst auch, dass ein Angreifer auf verschlüsselte, sensible Daten, nach Analyse des für die Übertragung zwischen Web-Browser und Hintergrundsystem genutzten Verschlüsselungsmechanismus, im Klartext zugreifen kann.
T.Auth	Ein Angreifer erhält unter einer fremden Nutzerkennung oder der Verwendung fremder Rollen- oder Gruppenzugehörigkeit Zugriff auf sensible Daten anderer Nutzer.

¹ Das Aufweichen der betriebssystemeigenen Sicherheitsfunktionalitäten durch Erlangen von erhöhten Zugriffsrechten und Ermöglichen der Installation von Applikationen aus unbekannten Quellen.

T.DevFunctions	Ein Angreifer nutzt in der Web-Anwendung versteckte oder verbliebene Entwickler- bzw. Debuggingfunktionen zur Unterwanderung von Sicherheitsmaßnahmen.
T.Impersonation	Ein Angreifer erhält durch fehlende oder fehlerhafte Zugriffskontrollen oder durch Erraten von Zugriffsparametern unberechtigten Zugriff auf sensible Daten oder kostenpflichtige Funktionen eines anderen Nutzers.
T.InfoDisclosure	Ein Angreifer führt eine Analyse der Web-Anwendung durch und findet Referenzen auf z.B. Entwicklerinstanzen, festkodierte Testaccounts oder Daten zur Verwendung in Verschlüsselungsroutinen.
T.Integrity	Ein Angreifer ist in der Lage, Daten innerhalb des Arbeitsspeichers oder auf dem Transportweg unbemerkt zu manipulieren oder zu löschen.
T.VisibleAsset	Der Angreifer kann durch „Schulter-Surfen“ ² (engl. Shoulder Surfing) sensible Daten, die auf der Web-Anwendung dargestellt werden, mitlesen.

3.1.3 Organisatorische Sicherheitspolitiken

OSP.Authorization	Der Hersteller entwickelt ein Autorisierungskonzept nach dem Prinzip der minimalen Rechtevergabe („Need-to-know-Prinzip“), welches sowohl den lesenden, als auch den schreibenden Zugriff auf sensible Daten steuert. Das Autorisierungskonzept muss unabhängig von der Authentifizierung implementiert werden.
OSP.BrowserCred	Aktuelle Plattformen mit Web-Browser bieten in aller Regel an, Login-Informationen zu Web-Angeboten gesichert zu speichern, um bei einem erneuten Besuch des Web-Angebots den Nutzern einen vereinfachten Zugang anbieten zu können. Die Web-Anwendung weist den Nutzer auf die damit verbundenen Restrisiken geeignet hin.
OSP.User	Der Nutzer ist über die Nutzungsbedingungen der Web-Anwendung auf seine Mitwirkungspflichten hinzuweisen. Stimmt der Nutzer diesen Nutzungsbedingungen nicht zu, MUSS er von der Nutzung des Angebots ausgeschlossen werden.
OSP.CriticalUpdates	Der Hersteller überprüft und überwacht die für die Web-Anwendung nutzbaren Browser sowie die für die Web-Anwendung genutzte Drittanbieter-Software ³ dauerhaft auf ausnutzbare Schwachstellen. Der Hersteller muss beim Bekanntwerden von Schwachstellen kurzfristig ein Update der Web-Anwendung bereitstellen, welches die Schwachstelle unzugänglich macht oder deren Ausnutzbarkeit verringert.
OSP.DataSovereignty	Die Web-Anwendung stellt die Datenhoheit des Nutzers sicher. Die Anwendung weist den Nutzer auf bestehende Risiken durch die Konfiguration seines Endgeräts hin und lässt ihn entscheiden, die Nutzung abzubrechen. Auf Anforderung des Nutzers löscht die Web-Anwendung bereits erfasste Daten im Hintergrundsystem und weist den Nutzer darauf hin, dass ggf. lokal gespeicherte Daten (z.B. gespeicherte Formulardaten oder Browsercache) durch den Nutzer selbst gelöscht werden müssen. Exportiert der Nutzer sensible Daten unverschlüsselt und entzieht diese damit der Überwachung durch die Web-Anwendung, übernimmt der damit die Verantwortung.

² Beim Schulter-Surfen blickt der Angreifer unbemerkt über die Schulter auf das Gerät um Informationen zu erhalten.

³ Unter einer Drittanbieter-Software soll die Zusammenfassung von Funktionalitäten verstanden werden, die nicht in der Hoheit des Entwicklers der Anwendung entstanden sind und die auch nicht Teil der Funktionalität der verwendeten Betriebssystemplattform ist.

OSP.Disclosure	Der Hersteller bietet einen niederschweligen Prozess zum Melden von Schwachstellen an. Das heißt, er stellt leicht auffindbare Kontaktinformationen zur Sicherheits-Abteilung bereit und bietet eine Möglichkeit, um Schwachstellen anonym zu melden.
OSP.Purpose	Jegliche Datenerhebung, -verarbeitung, -speicherung und -weitergabe darf nur mit einer Zweckbindung erfolgen. Der Hersteller veröffentlicht dafür den rechtmäßigen Zweck der Web-Anwendung und darüber hinaus welche Daten wie verarbeitet werden und wo und wie lange sie gespeichert werden.
OSP.SecurityLifeCycle	Der Hersteller realisiert einen Entwicklungszyklus, dessen Teilschritte darauf ausgelegt sind, die Sicherheit der Web-Anwendung zu stärken. Darunter fallen Maßnahmen, mit denen bösartige Aktivitäten erkannt werden und der Betreiber angemessene Gegenmaßnahmen einleiten kann.

3.1.4 Restrisiken

Mobile Endgeräte sind besonders anfällig für Diebstahl. Auch bei der Nutzung der sicheren Quellen (s.o.) ist nicht ausgeschlossen, dass auf diesen Schadsoftware zum Download angeboten wird. Installierte Schadsoftware kann bestehende Schwachstellen ausnutzen.

Der Betrieb des Hintergrundsystems bei Public Cloud-Anbietern beinhaltet besondere Risiken für die sensiblen Daten der Nutzer (siehe Teil 3 der TR-03174).

Der Schutz von Kommunikationsverbindungen zwischen der Plattform, der Anwendung und dem Hintergrundsystem könnte ebenfalls Schwachstellen und Risiken beinhalten. Diesem ist besondere Aufmerksamkeit sowohl in der Planung und Erstellung, als auch bei der Auditierung zu widmen.

Mit der Annahme A.Browser wurde vorausgesetzt, dass der genutzte Web-Browser frei von Schwachstellen ist. Dies kann in der Realität nicht vollständig angenommen werden. Einige der im Kapitel 4 aufgeführten Empfehlungen versuchen dieses Restrisiko zu minimieren.

Weitere Restrisiken bestehen darin, dass der Nutzer bestimmte Eigenschaften der Plattform bzw. des Web-Browsers nutzt, die wiederum mit einer Gefährdung sensibler Daten verbunden sein können. Einige Empfehlungen sollen sicherstellen, dass der Nutzer über die Nutzungsbedingungen umfassend über seine Verantwortlichkeiten aufgeklärt wird. Mithin eliminieren die Nutzungsbedingungen das Restrisiko für die Web-Anwendung formal. Es obliegt dem Nutzer mit diesen Restrisiken verantwortlich umzugehen.

Auf Grund der beschriebenen Einschränkungen und bezogen auf den Umfang der vorliegenden TR, ist eine abschließende Aussage über die Sicherheit der mobilen Web-Anwendung, selbst unter Berücksichtigung aller aufgeführten Prüfaspekte, kaum möglich. Um die Sicherheit der gesamten Web-Anwendung zu erhöhen, ist es erforderlich weitere Literatur zu studieren, die bestehenden Restrisiken zu kennen und diese entsprechend zu behandeln.

4 Empfehlungen

Im Folgenden sind die Empfehlungen an eine Web-Anwendung im Finanzwesen aufgeführt. Diese basieren auf technischen und teilweise regulatorischen Vorgaben, deren Umsetzung für die Informationssicherheit von großer Bedeutung sind. Prüfkriterium und -tiefe (Anlage B) leiten sich aus diesen Empfehlungen ab. Diese müssen bei individuellen Anforderungen oder Bedrohungen, welche über den Standard hinausgehen, ergänzt werden.

4.1 Anwendungszweck

Tabelle 2: Anwendungszweck

Kürzel	Empfehlungen
O.Purp_1	Der Hersteller MUSS die rechtmäßigen Zwecke der Web-Anwendung und die Verarbeitung von personenbezogenen Daten dem Nutzer gegenüber offenlegen (z.B. in den Nutzungsbedingungen).
O.Purp_2	Zur Wahrung der Datensparsamkeit und Zweckbindung DARF die Web-Anwendung KEINE Daten erheben und verarbeiten, die nicht dem rechtmäßigen Zweck der Anwendung dienen bzw. für diesen notwendig sind.
O.Purp_3	Die Web-Anwendung MUSS es ermöglichen, dass der Nutzer eine bereits erteilte Einwilligung jederzeit widerrufen und entziehen kann. Der Nutzer MUSS vor der Einwilligung über die Möglichkeit des Widerrufs und die sich daraus ergebenden Veränderungen im Verhalten der Anwendung informiert werden. Erhobene, personalisierte Sicherheitsmerkmale MÜSSEN nach einem Widerruf sowie einer Deaktivierung sicher vernichtet werden.
O.Purp_4	Die Web-Anwendung SOLL eine Übersicht zur Überwachung und zum Management der in der Web-Anwendung erteilten Berechtigungen zur Verfügung stellen.
O.Purp_5	Setzt die Web-Anwendung Drittanbieter-Software ein, MÜSSEN alle verwendeten Funktionen für die rechtmäßigen Zwecke der Anwendung erforderlich sein. Die Anwendung MUSS anderweitige Funktionen sicher deaktivieren.
O.Purp_6	Wurde die Geschäftsbeziehung ausschließlich online abgeschlossen, MÜSSEN die geltenden Vertragsbedingungen in der Web-Anwendung bereitgestellt werden.
O.Purp_7	Jegliche Meldung der Web-Anwendung SOLL für den Nutzer verständlich sein.
O.Purp_8	Die Web-Anwendung SOLL dem Nutzer barrierearme Best-Practice-Empfehlungen zum sicheren Umgang mit der Anwendung und ihrer Konfiguration bereitstellen.

4.2 Architektur

Tabelle 3: Architektur

Kürzel	Empfehlungen
O.Arch_1	Informationssicherheit MUSS ein fester Bestandteil des Softwareentwicklungs- und Lebenszyklus für die gesamte Web-Anwendung und das Hintergrundsystem sein. Es MUSS berücksichtigt werden, dass die Anwendung in der Produktivphase sensible Daten verarbeiten wird. Die Architektur der Anwendung MUSS dafür die sichere Erhebung, Verarbeitung, Speicherung und Löschung der sensiblen Daten in einem Datenlebenszyklus gewährleisten. Die Sicherheits-mechanismen MÜSSEN dokumentiert sein.

O.Arch_2	Der Lebenszyklus von kryptographischem Schlüsselmaterial MUSS einer ausgearbeiteten Richtlinie folgen, die Eigenschaften wie die Zufallszahlenquelle, detaillierte Angaben zur Aufgabentrennung von Schlüsseln, Ablauf von Schlüsselzertifikaten, Integritätssicherung durch Hash-Algorithmen, etc., umfasst. Die Richtlinie SOLL auf anerkannten Standards wie [TR02102-2] und [NIST80057] basieren.
O.Arch_3	In Backups gespeicherte sensible Daten SOLLEN gemäß dem aktuellen Stand der Technik verschlüsselt sein. Dies schließt das Persistieren sensibler Daten durch den Browser, etwa in dessen Cache, mit ein.
O.Arch_4	Nutzt die Web-Anwendung Drittanbieter-Software, MUSS der Hersteller sicherstellen, dass nur solche Drittanbieter-Software zum Einsatz kommt, deren Funktionen sicher genutzt werden können und dem Nutzer Informationen über den Nutzungsumfang und die eingesetzten Sicherheitsmechanismen transparent dargestellt wird. Die Web-Anwendung MUSS sicherstellen, dass ungenutzte Funktionen deaktiviert sind.
O.Arch_5	Die Architektur der Web-Anwendung SOLL einem minimalistischen Ansatz folgen und mit einer serverseitig lokalisierten Verarbeitungslogik realisiert sein, d.h. es SOLLEN keine komplexen aktiven Inhalte (Java Applets, ActiveX-Plugin, o.ä.) verwendet werden.
O.Arch_6	Der Hersteller SOLL dem Nutzer eine barrierearme Möglichkeit bereitstellen, um Sicherheitsprobleme zu melden. Die Kommunikation SOLL über einen verschlüsselten Kanal stattfinden.
O.Arch_7	Die Web-Anwendung MUSS beim Start die Verfügbarkeit und Aktualität des genutzten Web-Browsers prüfen. Wenn die Installation eines sicherheitsrelevanten Updates noch nicht erfolgt ist, DARF die Web-Anwendung KEINEN Zugriff auf sensible Daten ermöglichen.
O.Arch_8	Die Web-Anwendung SOLL HTTP-Server-Header nutzen, die dem aktuellen Stand der Technik entsprechen und die Sicherheit der Anwendung erhöhen (z.B. HTTP Strict Transport Security (HSTS), Content Security Policy (CSP) und X-Frame-Options).
O.Arch_9	Die Entwickelnden SOLLEN die Softwarearchitektur der Webanwendung mit allen Bestandteilen und Abhängigkeiten dokumentieren. Die Dokumentation SOLL bereits während des Entwicklungsverlaufs aktualisiert und angepasst werden. Die Dokumentation SOLL so gestaltet sein, dass sie schon in der Entwicklungsphase benutzt werden kann und Entscheidungen nachvollziehbar sind. In der Dokumentation SOLLEN alle für den Betrieb notwendigen Komponenten gekennzeichnet werden, die nicht Bestandteil der Webanwendung sind.
O.Arch_10	Webanwendungen und Webservices SOLLEN regelmäßig, mindestens einmal jährlich, auf Sicherheitsprobleme hin überprüft werden. Insbesondere SOLLEN regelmäßig Revisionen durchgeführt werden. Die Ergebnisse SOLLEN nachvollziehbar dokumentiert, ausreichend geschützt und vertraulich behandelt werden.

4.3 Quellcode

Tabelle 4: Quellcode

Kürzel	Empfehlungen
O.Source_1	Die Anwendung MUSS alle Eingaben vor deren Verarbeitung prüfen, um potenziell bösartige Werte vor der Verarbeitung herauszufiltern.
O.Source_2	Die Anwendung MUSS eingehende und ausgehende Daten maskieren, beziehungsweise von potenziell schadhafte Zeichen bereinigen oder deren Verarbeitung ablehnen.

O.Source_3	Fehlermeldungen und Log-Dateien DÜRFEN KEINE sensiblen Daten (z. B. User Identifier oder Session-IDs) enthalten. Eine fehlgeschlagene Authentifizierung DARF KEINE Rückschlüsse auf Elemente der Authentifizierung zulassen.
O.Source_4	Potenzielle Ausnahmen im Programmablauf (Exceptions) MÜSSEN abgefangen, kontrolliert behandelt und dokumentiert werden. Technische Fehlerbeschreibungen (z.B. Stack Traces) DÜRFEN dem Nutzer NICHT angezeigt werden. Die Rückantworten und Fehlermeldungen der Webanwendung DÜRFEN KEINE Informationen enthalten, die Angreifenden Hinweise darauf geben, wie man Sicherheitsmechanismen umgehen kann.
O.Source_5	Bei Ausnahmen im Programmablauf (Exceptions) SOLL die Web-Anwendung Zugriffe auf sensible Daten abbrechen und diese im Speicher sicher löschen.
O.Source_6	Alle Optionen zur Unterstützung der Entwicklung (z. B. Entwickler-URLs, Testmethoden, Überreste von Debugmechanismen etc.) MÜSSEN in der Produktiv-Version vollständig entfernt sein.
O.Source_7	Vor der produktiven Bereitstellung der Anwendung SOLLEN moderne Sicherheitsmechanismen, wie beispielsweise Obfuskation und Bundler, verwendet werden.
O.Source_8	Für die Entwicklung der Anwendung SOLLEN Werkzeuge zur statischen Codeanalyse eingesetzt werden.
O.Source_9	Nutzt die Web-Anwendung URL-Weiterleitungen (URL-Redirects), MÜSSEN diese kontrolliert erfolgen.
O.Source_10	Die Web-Anwendung MUSS Maßnahmen vorsehen, die verhindern, dass Funktionalitäten, die nicht in der Entwicklungshoheit des Herstellers liegen, in die Web-Anwendung eingeschleust und zur Ausführung gebracht werden.
O.Source_11	Sensible Daten DÜRFEN NICHT in der URL vorkommen. Die Web-Anwendung MUSS solche Daten in HTTP Request Headern oder POST-Parametern verarbeiten.
O.Source_12	Es MUSS sichergestellt sein, dass die Nutzer Dateien nur im von der Web-Anwendung vorgesehenen Pfad speichern können.
O.Source_13	Die Dateien mit den Quelltexten der Webanwendung MÜSSEN vor unerlaubten Abrufen geschützt werden.
O.Source_14	Zum Schutz vor Denial-of-Service (DoS)-Angriffen SOLLEN ressourcenintensive Operationen vermieden werden. Falls ressourcenintensive Operationen notwendig sind, dann SOLLEN diese besonders abgesichert werden. Bei Webanwendungen SOLL ein möglicher Überlauf von Protokollierungsdaten überwacht und verhindert werden.

4.4 Drittanbieter-Software

Tabelle 5: Drittanbieter-Software

Kürzel	Empfehlungen
O.TrdP_1	Der Anbieter MUSS eine zentrale und vollständige Liste von Abhängigkeiten durch Drittanbieter-Software führen.
O.TrdP_2	Drittanbieter-Software MUSS in der neuesten oder der ihr vorhergehenden, für die Veröffentlichung vorgesehenen Version verwendet werden.
O.TrdP_3	Drittanbieter-Software MUSS durch den Hersteller regelmäßig (durch Auswertung öffentlich verfügbarer Informationen oder durch statische/dynamische Testmethoden) auf Schwachstellen überprüft werden. Überreste von Optionen zur Unterstützung der Entwicklung (vgl.O.Source_6) sind hierbei als Schwachstelle zu werten. Der Hersteller MUSS für alle öffentlich

	bekannten Schwachstellen analysieren, inwieweit die Schwachstelle die Sicherheit des Gesamtsystems beeinträchtigt. Software, bzw. Funktionen aus Drittanbieter-Software DÜRFEN bei bekannten Schwachstellen, die die Sicherheit des Gesamtsystems betreffen, NICHT eingesetzt werden.
O.TrdP_4	Sicherheitsupdates für Drittanbieter-Software MÜSSEN zeitnah integriert und per Update dem Nutzer zur Verfügung gestellt werden. Der Hersteller MUSS ein Sicherheitskonzept vorlegen, das anhand der Kritikalität ausnutzbarer Schwachstellen die geduldete Weiternutzung für die Web-Anwendung, bzw. das Hintergrundsystem festlegt. Nachdem die Übergangsfrist (Grace Period) abgelaufen ist, DARF die Web-Anwendung NICHT mehr zur Benutzung angeboten werden.
O.TrdP_5	Vor der Verwendung von Drittanbieter-Software MUSS deren Quelle auf Vertrauenswürdigkeit geprüft werden.
O.TrdP_6	Über Drittanbieter-Software eingehende Daten MÜSSEN validiert werden.
O.TrdP_7	Drittanbieter-Software, die nicht mehr gewartet wird, DARF NICHT verwendet werden.

4.5 Kryptographische Umsetzung

Tabelle 6: Kryptographische Umsetzung

Kürzel	Empfehlungen
O.Cryp_1	Beim Einsatz von Verschlüsselung in der Web-Anwendung DÜRFEN KEINE fest einprogrammierten geheimen, bzw. privaten Schlüssel eingesetzt werden.
O.Cryp_2	Die Anwendung MUSS auf bewährte Implementierungen zur Umsetzung krypto-graphischer Primitive und Protokolle zurückgreifen (vgl. [TR02102-2]).
O.Cryp_3	Die Wahl kryptographischer Primitive MUSS passend zum Anwendungsfall sein und dem aktuellen Stand der Technik (siehe [TR02102-1]) entsprechen. Die Vertraulichkeit, z.B. der Authentifizierungsmerkmale, MUSS zu jedem Zeitpunkt gewährleistet sein.
O.Cryp_4	Kryptographische Schlüssel DÜRFEN NICHT für mehr als genau einen Zweck eingesetzt werden.
O.Cryp_5	Die Stärke der kryptographischen Schlüssel MUSS dem aktuellen Stand der Technik entsprechen (siehe [TR02102-1]).
O.Cryp_6	Das geheime kryptografische Material SOLL vor unbefugter Offenlegung geschützt sein. Der Prozess zur Verschlüsselung SOLL vollständig dokumentiert sein.
O.Cryp_7	Alle kryptographischen Operationen SOLLEN in einer vor Manipulation und Offenlegung geschützten Umgebung stattfinden.
O.Cryp_8	Alle Zufallswerte MÜSSEN über einen starken kryptographischen Zufallszahlengenerator erzeugt werden.

4.6 Authentisierung und Authentifizierung

Tabelle 7: Authentisierung und Authentifizierung

Kürzel	Empfehlungen
O.Auth_1	Der Hersteller MUSS ein Konzept zur Authentisierung auf angemessenem Vertrauensniveau [TR03107-1], zur Autorisierung (Rollenkonzept) und zum Beenden einer Anwendungssitzung

	dokumentieren. Der Auswahlprozess der Authentisierungsmethode MUSS dokumentiert werden.
O.Auth_2	Ist eine Zwei-Faktor-Authentifizierung gefordert, z.B. aufgrund regulatorischer Vorgaben oder dem Umgang mit besonders schützenswerten Daten, MÜSSEN die Faktoren aus den Kategorien Wissen, Besitz und Inhärenz kommen, wobei die Faktoren aus unterschiedlichen Kategorien sein MÜSSEN . Die Faktoren MÜSSEN vor unbefugtem Zugriff bzw. Verwendung geschützt werden.
O.Auth_3	Der Nutzer MUSS über ungewöhnliche Anmeldevorgänge informiert werden.
O.Auth_4	Das IT-System bzw. die IT-Anwendung SOLL nach jedem erfolglosen Authentisierungsversuch weitere Anmeldeversuche zunehmend verzögern (Time Delay). Die Gesamtdauer eines Anmeldeversuchs SOLL begrenzt werden können. Nach Überschreitung der vorgegebenen Anzahl erfolgloser Authentisierungsversuche SOLL das IT-System bzw. die IT-Anwendung die Benutzendenkennung sperren.
O.Auth_5	Die Anwendung MUSS nach einer angemessenen Zeit in der sie nicht aktiv verwendet wurde (idle time) eine erneute Authentisierung fordern. Alle alten Sitzungsdaten SOLLEN ungültig und gelöscht sein. Diese Regelungen sollen auch für die Verbindung zum Hintergrundsystem gelten.
O.Auth_6	Die Authentisierungsdaten DÜRFEN NICHT ohne eine erneute Authentifizierung des Nutzers geändert werden.
O.Auth_7	Die Anwendung MUSS für die Anbindung eines Hintergrundsystems eine dem Stand der Technik entsprechende Authentifizierung verwenden.
O.Auth_8	Authentisierungsdaten, wie bspw. Session-IDs bzw. Authentisierungstoken, MÜSSEN als sensible Daten geschützt werden. Session-IDs MÜSSEN zufällig und mit ausreichender Entropie erzeugt werden. Wenn Session-IDs übertragen und von den Clients gespeichert werden, MÜSSEN sie ausreichend geschützt übertragen werden.
O.Auth_9	Wird eine Anwendungssitzung ordnungsgemäß beendet, MUSS die Anwendung das Hintergrundsystem darüber informieren, sodass Session-Identifizier bzw. Authentisierungstoken sicher gelöscht werden. Dies gilt sowohl für das aktive Beenden durch den Benutzer (log-out), als auch für das automatische Beenden durch die Anwendung.
O.Auth_10	Bei Änderung der Zugangsparameter MUSS der Nutzer über die zuletzt hinterlegten, gültigen Kontaktdaten über die Änderung informiert werden. Dem Nutzer SOLL über diesem Weg eine Möglichkeit geboten werden, die gemeldete Änderung zu sperren und nach entsprechender Authentifizierung neue Zugangsparameter zu setzen.
O.Auth_11	Wird der Zugang zur Web-Anwendung, z.B. aufgrund zu vieler fehlerhafter Anmeldeversuche, temporär gesperrt, MUSS die Anwendung hierüber informieren bzw. warnen, bevor diese Sperrung dauerhaft wird. Bei einer dauerhaften Sperrung MUSS der Benutzer die Möglichkeit haben, die Nutzung wiederzuerlangen.
O.Pass_1	Bei einer Authentifizierung mittels Benutzername und Passwort SOLLEN starke Passwortrichtlinien existieren. Diese SOLLEN sich am aktuellen Stand gängiger „Best-Practices“ orientieren.
O.Pass_2	Für die Einrichtung der Authentisierung mittels Benutzername und Passwort KANN die Stärke des verwendeten Passworts dem Nutzer angezeigt werden. Informationen über die Stärke des gewählten Passworts DÜRFEN NICHT gespeichert werden.
O.Pass_3	Der Nutzer MUSS die Möglichkeit haben, sein Passwort zu ändern.
O.Pass_4	Wird die Anwendung zusammen mit einem Hintergrundsystem genutzt, SOLL das Ändern und Zurücksetzen von Passwörtern protokolliert werden. Das Hintergrundsystem SOLL den Nutzer über das Ändern und Zurücksetzen von Passwörtern informieren, dabei SOLL ein separater Kanal genutzt werden.

O.Pass_5	Werden Passwörter gespeichert, MÜSSEN diese gemäß den aktuellen Sicherheitsstandards geschützt werden.
O.Pass_6	Die Web-Anwendung DARF sensible Daten NICHT auf dem Bildschirm darstellen, außer dies ist für den primären Zweck der Anwendung erforderlich oder wird durch den Nutzenden explizit ausgewählt.

4.7 Datensicherheit

Tabelle 8: Datensicherheit

Kürzel	Empfehlungen
O.Data_1	Die Werkseinstellung der Web-Anwendung MUSS die maximale Sicherheit bieten.
O.Data_2	Vertrauliche Daten innerhalb der Anwendung MÜSSEN durch sichere, kryptografische Algorithmen abgesichert werden.
O.Data_3	Exportiert der Nutzer sensible Daten unverschlüsselt MUSS der Nutzer durch die Web-Anwendung darauf aufmerksam gemacht werden, dass der Nutzer selbst die Verantwortung für die Datensicherheit dieser exportierten Daten übernimmt.
O.Data_4	Alle erhobenen sensiblen Daten DÜRFEN NICHT über die Dauer ihrer jeweiligen Verarbeitung hinaus in der Web-Anwendung gehalten werden.
O.Data_5	Bei der Eingabe sensibler Daten über die Tastatur SOLL die Web-Anwendung unterbinden, dass Aufzeichnungen für Dritte erkennbar werden.
O.Data_6	Sensible Daten DÜRFEN clientseitig NICHT zwischengespeichert werden. Die Anwendung KANN alternativ eine eigene Zwischenablage implementieren, welche vor dem Zugriff durch andere Anwendungen geschützt ist
O.Data_7	Die Web-Anwendung SOLL sicherstellen, dass bei ihrer Beendigung alle sensiblen Daten und anwendungsspezifischen Anmeldeinformationen im Web-Browser nicht mehr zugreifbar sind. Dies schließt insbesondere Cookies und Webstorage mit ein.
O.Data_8	Die Web-Anwendung MUSS bei endgültiger Beendigung der Nutzung alle sensiblen Daten und anwendungsspezifische Anmeldeinformationen vollständig löschen bzw. unzugänglich machen.
O.Data_9	Für alle Cookies, auf die nicht mittels JavaScript zugegriffen wird, MUSS das HTTP-Only-Flag verwendet werden.
O.Data_10	Für alle Cookies, die sensible Daten enthalten, MUSS das Secure-Flag gesetzt sein.
O.Data_11	Für alle Formularfelder mit sensiblen Eingabedaten MUSS die Autocomplete-Funktion abgeschaltet sein.
O.Data_12	Im Browser persistierte Daten SOLLEN für weitere Hosts einer Domain unlesbar sein (d.h. Vermeidung von Domain-Cookies).

4.8 Netzwirkkommunikation

Tabelle 9: Netzwirkkommunikation

Kürzel	Empfehlungen
--------	--------------

O.Ntwk_1	Die Netzwerkkommunikation zwischen den Verbindungspartnern MUSS gegenseitig authentifiziert werden und die Kommunikation MUSS verschlüsselt erfolgen.
O.Ntwk_2	Die Konfiguration der TLS-Verbindungen MUSS dem aktuellen Stand der Technik entsprechen (vgl. [TR02102-2]).
O.Ntwk_3	Die Web-Anwendung MUSS die Sicherheitsfunktionalität der jeweilig verwendeten Betriebssystem-Plattform und des Browsers verwenden, um sichere Kommunikationskanäle aufzubauen.
O.Ntwk_4	Die Web-Anwendung SOLL die Verwendung von Zertifikaten, deren Zertifikatskette dem Hersteller nicht vertrauenswürdig erscheint, unterbinden.
O.Ntwk_5	Zum Schutz vor Clickjacking, Cross-Site-Scripting und anderen Angriffen SOLLEN geeignete HTTP-Response-Header gesetzt werden. Die verwendeten HTTP-Header SOLLEN auf die Webanwendung abgestimmt werden. Die verwendeten HTTP-Header SOLLEN so restriktiv wie möglich sein.

4.9 Plattformspezifische Interaktion

Tabelle 10: Plattformspezifische Interaktion

Kürzel	Empfehlungen
O.Plat_1	Für die Nutzung der Web-Anwendung SOLL das Endgerät über einen aktivierten Geräteschutz (Passwort, Mustersperre, o. ä.) verfügen. Im Fall eines nicht aktivierten Geräteschutzes MUSS der Hersteller den Nutzer über die damit verbundenen Risiken aufklären.
O.Plat_2	Die Web-Anwendung DARF Berechtigungen, die für die Erfüllung ihres primären Zwecks nicht notwendig sind, NICHT einfordern.
O.Plat_3	Die Web-Anwendung MUSS den Nutzer auf den rechtmäßigen Zweck der anzufragenden Berechtigungen und auf die Auswirkungen hinweisen, die eintreten, falls der Nutzer diese nicht gewährt.
O.Plat_4	Die Web-Anwendung DARF KEINE sensiblen Daten in erweiterten Meldungen oder Benachrichtigungen, die nicht vom Nutzer explizit eingeschaltet wurden (siehe O.Plat_5), anzeigen.
O.Plat_5	Die Web-Anwendung KANN dem Nutzer die Optionen bieten, erweiterte Meldungen und Benachrichtigungen, ggf. auch mit sensiblen Inhalten, anzuzeigen. Bei Werkseinstellung MUSS diese deaktiviert sein.
O.Plat_6	Die Web-Anwendung MUSS das Nachladen von Inhalten auf Quellen beschränken, die unter der Kontrolle des Herstellers sind oder durch den Hersteller autorisiert wurden.
O.Plat_7	Die Web-Anwendung MUSS den Nutzer über das Risiko informieren, dass ggf. nach Beendigung der Web-Anwendung nutzerspezifischen Daten im Arbeitsspeicher verbleiben können.
O.Plat_8	Der Nutzer MUSS über Sicherheitsmaßnahmen informiert werden, sofern diese durch den Nutzer umsetzbar sind.

5 Anforderungen an die Prüfung

Die Prüfung von Web-Anwendungen im Finanzwesen orientiert sich an den Anforderungen (Kapitel 4). Aus diesen werden Testcharakteristika und Prüftiefe abgeleitet, welche als Basis einer Prüfung dienen (siehe Anhang B). Unterstützend kann der Hersteller Aussagen tätigen, in denen er die betreffende Umsetzung skizziert und eine Referenz auf die jeweilige Implementierung angibt. Die untenstehende Tabelle legt dar, welche Prüfschritte mindestens für die jeweilige Prüftiefe gefordert sind.

Tabelle 11: Prüftiefen und Mindestanforderungen

Prüftiefe	Mindestanforderungen an die Prüfung
CHECK	Der Evaluator validiert (englisch „check“, analog Begriffsverwendung in der Common Criteria Evaluation Methodology) die vom Hersteller beschriebene Maßnahme im Hinblick auf ihre Wirksamkeit und räumt bestehende Zweifel (Plausibilitätsprüfung) aus, ob der Prüfaspekt und die damit verbundene Sicherheitsproblematik umfassend durch die beschriebenen Maßnahmen adressiert werden. Hierbei MUSS der Evaluator den aktuellen Stand der Technik berücksichtigen. Die Validierung KANN weitergehende Schritte, z.B. eine Quelltextanalyse, umfassen, falls der Evaluator diese für eine Einschätzung benötigt.
EXAMINE	Der Evaluator untersucht (englisch „examine“, analog zur Common Criteria Evaluation Methodology) die betreffende Testcharakteristik. Der Evaluator MUSS in seiner Prüfung über die Mindestanforderungen für „CHECK“ hinausgehen: In der Regel wird dies durch umfassende Quelltextanalyse der relevanten Implementierungsanteile und Penetrationstests geschehen. Die Unterstützung durch den Hersteller kann genutzt werden. „EXAMINE“ erfordert in jedem Fall eine eigenständige Beurteilung durch den Evaluator.

Bei Prüftiefe „CHECK“ wählt der Prüfer, wie hoch die Abdeckung der Analyse für seine Einschätzung notwendig ist. Für „EXAMINE“ muss der Prüfer erläutern, inwiefern sämtliche relevanten Codezeilen in Betracht gezogen wurden.

5.1 Protokollierung der Prüfungsergebnisse

Die Protokollierung der Testergebnisse ist so zu gestalten, dass unbeteiligte Dritte in die Lage versetzt werden, anhand der Angaben aus dem Prüfbericht die vorgenommenen Prüfschritte zu wiederholen und dabei das gleiche Ergebnis zu erzielen. Hierzu ist es neben der Beschreibung der einzelnen Prüfschritte notwendig, dass die verwendeten Prüfwerkzeuge in den verwendeten Versionen in dem Prüfbericht ersichtlich sind. Die untenstehende Tabelle definiert die zulässigen Prüfergebnisse, welche sich aus der Prüfung einer Charakteristik ergeben können. Der TR-Prüfer begründet, wie er zu einem entsprechenden Ergebnis gekommen ist.

Tabelle 12: Mögliche Prüfergebnisse

Ergebnis	Notwendige Angaben
PASS	Der Prüfer erläutert sein Verständnis, warum die Hersteller-Implementierung das geforderte Sicherheitsziel erfüllt. Der Prüfbericht führt die durchgeführten Prüfschritte sowie das Prüfergebnis aus.
INCONCLUSIVE	Der Prüfbericht spezifiziert/referenziert die fehlenden oder inkonsistenten Informationen, damit der Hersteller die Nicht-Konformität zu dem betreffenden Aspekt des Sicherheitsziel bereinigen kann.
FAIL	Die geprüfte Anwendung verfehlt das betreffende Sicherheitsziel. Der Prüfer dokumentiert, inwiefern Angriffe durch Sicherheitsmaßnahmen in der Umgebung der Anwendung (z.B. operative Maßnahmen) verhindert werden können. Der Prüfer nimmt eine Evidenz der Verletzung der Prüfcharakteristik in die Protokollierung auf. Der Prüfer nimmt das durch die Verletzung der Testcharakteristik entstehende Risiko in die Risikoabschätzung mit auf.
NOT APPLICABLE (N/A)	Die geprüfte Anwendung verfügt über keinerlei Implementierung der durch den Prüfaspekt zu schützenden Funktionalitäten. Daher kann die betreffende Testcharakteristik nicht auf die zu prüfende Anwendung angewandt werden.

5.2 Risikoanalyse und -bewertung

Die Prüfer identifizieren bestehende Restrisiken beim Einsatz der Anwendung im Finanzwesen. Mit der Aufdeckung bestehender Restrisiken wird dem Umstand Rechnung getragen, dass der Verlust von Finanzdaten zu einem Schaden für den Nutzer führt und ausreichende Schutzmaßnahmen zum Zeitpunkt der TR-Prüfung nicht identifiziert werden konnten. Die Risikobewertung muss mindestens folgende Aspekte umfassen:

- Identifikation von Risiken aus der unterlassenen oder unzureichenden Umsetzung von „SOLL“-Anforderungen in Sicherheitszielen.
- Implementierungsspezifische Risiken.
- Risiken durch Integration in der geplanten Betriebsumgebung.
- Berücksichtigung der Eignung des Monitorings sowie vorgesehene Reaktionsmöglichkeiten.

Grundlage für die Prüfung und das daraus resultierende Prüfurteil soll ein dokumentiertes Risikomanagementverfahren sein. Als allgemeine Referenz werden BSI Standard 200-3 [BSI200-3], ISO 27005 [ISO27005] und Anhang B der Common Criteria Evaluation Methodology [CEM] genannt. Vergleichbare Risikomanagementverfahren sind möglich.

Die Prüfer führen eine methodische Risikoanalyse durch, die mindestens folgende Schritte umfassen muss:

1. Sicherheitsproblem vollständig aufarbeiten – Ausgangspunkt der Risikoanalyse sind die Bedrohungen, Annahmen und Sicherheitspolitiken der Anwendung (siehe Kapitel 3). Der Prüfer etabliert eine vollständige Liste aller sensiblen Daten, die in der Anwendung erfasst, erzeugt oder genutzt werden. Sensible Daten, die alleine im Hintergrundsystem verarbeitet werden, sind durch die Annahme A.Backend (siehe Kapitel 3.1.1) abgedeckt.
2. Schutzbedarf feststellen – die IT-Sicherheit betrachtet generell den Schutzbedarf hinsichtlich Vertraulichkeit, Integrität, Authentizität und Verfügbarkeit. Der Prüfer klassifiziert den jeweiligen Schutzbedarf aller verarbeiteten Daten, vgl. Anhang B in [ISO27005]. Die Daten im Rahmen der TR werden anhand ihrer Kritikalität unterschieden (vgl. Tabelle 14).

3. Risikoszenarien bewerten – Der TR-Prüfer führt unter Berücksichtigung der etablierten Gegenmaßnahmen eine Bewertung von Risikoszenarien durch. Es muss dafür ein dokumentierter, ganzheitlicher Ansatz auf die sensiblen Daten der Anwendung durchgeführt werden, beispielsweise [ISO27005], Abschnitt 8.3 und Anhänge C/D/E.

In die Bewertung durch den Prüfer geht ein, welche Schutzmaßnahmen im Produkt realisiert sind, und deren Effektivität. Ebenfalls werden Vorgaben für die sichere Nutzung berücksichtigt, sofern diese dem Nutzer ausreichend dargelegt sind. Ob das Sicherheitsproblem angemessen behandelt wird, schätzen die Prüfer anhand der Schwierigkeit ermittelter Angriffspfade ein. (Die Schwierigkeit eines Angriffs ersetzt dabei die in der ISO 27005 referenzierte Eintrittswahrscheinlichkeit eines Risikos.)

Häufig werden für die Angriffsbewertung auf Anwendungen folgende Bewertungsprinzipien eingesetzt:

1. Zeitbasierter Ansatz – Der Prüfer schätzt den zeitlichen Aufwand eines Angreifers zur Überwindung der Sicherheitsmaßnahmen ein. Der Hersteller versichert, dass vor Ablauf dieser Zeit eine neue Produktversion mit neuem Schlüsselmaterial bereitgestellt wird (z.B. spätestens monatlich) und die Anwendung ist so beschaffen, dass Angriffe nur an der aktuellsten Produktversion ausgeführt werden können. Die Ausnutzung der Schwachstelle wird so unterbunden.
2. Reaktiver Ansatz – Hier analysiert der Prüfer die effektive Bekämpfung der Risikoszenarien mittels proaktiven Monitorings inkl. Reaktion. Beispielsweise werden Betriebsparameter erfasst und der Zugriff auf sensible Daten abgewehrt, sofern diese auf absichtliche Modifikationen hindeuten. Extern vom Hersteller selbst-realisierte Schutzmechanismen müssen mitbetrachtet werden.

Der Prüfer muss aufgrund der ermittelten Restrisiken ein Urteil abgeben, inwiefern das von der TR adressierte Sicherheitsproblem adäquat erfüllt wird. Eine Zertifizierung kann nur erteilt werden, falls die Prüfung ergibt, dass die Anforderungen für alle Daten erfüllt werden. Neben der Kompromittierung und dem Verlust von Daten spielt bei Anwendungen im Finanzwesen natürlich auch der unmittelbar mögliche finanzielle Schaden bei der Risikobewertung eine wichtige Rolle, die bei der Risikobewertung zu berücksichtigen ist.

Tabelle 13: Anforderung anhand der Daten-Kritikalität

Kritikalität	Beschreibung	Anforderung
Sehr hoch	Eine Verletzung des Schutzbedarfs führt zu einem nicht zu beziffernden oder potenziell schwerwiegenden Schaden für den Dateninhaber.	Die realisierten Maßnahmen werden als wirksam erachtet, sämtliche Risikoszenarien ohne Restrisiken auszuräumen.
Hoch	Eine Verletzung des Schutzbedarfs führt zu einem hohen oder mittleren Schaden für den Dateninhaber.	Die realisierten Maßnahmen reduzieren die Risikoszenarien erheblich. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und deren Auswirkungen dokumentieren. Im Einzelfall ist das Restrisiko darzustellen und kann Auflagen in der Nutzung der Zertifizierung verursachen.
Normal	Es kann höchstens ein geringer Schaden eintreten.	Die realisierten Maßnahmen reduzieren die Risikoszenarien. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und Restrisiken offenlegen.

Anhang A: Schutzbedarf sensibler Datenelemente

Abhängig von der realisierten Anwendung und der Kritikalität der jeweils verarbeiteten Datenelemente kann ein unterschiedlicher Schutzbedarf notwendig sein. Personenbezogene Daten unterliegen dem Datenschutz und dürfen nur bei Zweckbindung und nach Einverständnis verarbeitet werden.

Die Sensibilität verarbeiteter Datenelemente wird in der folgenden Tabelle bestimmt.

Tabelle 14: Schutzbedarf sensibler Datenelemente

Information	Sensibel	Übertragung an Hintergrundsystem erlaubt	Ablage außerhalb einer sicheren Umgebung erlaubt	Bemerkungen
Anwendungsdaten	Ja	Ja	Ja	-
Eingabedaten (von extern, dritter Partei, einer Drittanbieter-Software, über Tastatur)	Nein, falls nicht in anderer Kategorie speziell erfasst	Ja	Ja	-
Zugangsdaten	Ja	Ja	Ja	z.B. salted hashing. Zulässig sind Bibliotheken für Authentifizierung.
Kryptographische Schlüssel der Anwendung	Ja	Nein	Nein ⁴	Zulässig ist die Nutzung in Bibliotheken zur Kryptographie und Session-Handling.
Aggregierte Anwendungsdaten	Ja	Ja	Ja	Eine Anzeige darf nur mit integriertem Viewer erfolgen. Die Implementierung soll eine Speicherung auf dem Gerät vermeiden. Eine Speicherung ist ausschließlich verschlüsselt erlaubt.
Öffentliche Zertifikate	Nein	Ja	Ja	-

⁴ Ausgenommen sind Public Keys oder kryptografische Schlüssel von Drittanbietersoftware, sofern diese nicht der Kontrolle des Anwendungs-Entwicklers unterliegen und mobile Endgeräte, die nicht über eine sichere Umgebung (z.B. embedded Secure Element/Secure Enclave/Trusted Execution Environment) verfügen.

Anhang B: Prüftabellen

Maßgeblich für die Überprüfung der Web-Anwendung sind die Empfehlungen aus Kapitel 4. Diese werden um

- die Prüfaspekte
- die Prüftiefe sowie
- weiterführende Informationen bzw. Verweise auf externe Informationen

ergänzt.

Die Prüfaspekte geben das Vorgehen des Prüfers („Evaluator“) vor. Dies ist als Rahmen bzw. Mindestanforderung zu verstehen, da der Prüfer, wie in Kapitel 5 beschrieben, ein ggf. vorhandenes (Rest-) Risiko zu identifizieren und zu bewerten hat, um insgesamt zu einem nachvollziehbaren Prüfungsergebnis zu gelangen.

Die Prüftiefe wird in Kapitel 5.1 beschrieben.

Die weiterführenden Hinweise beinhalten, wenn vorhanden, Verweise auf korrespondierende Vorgaben aus sonstigen technischen und regulatorischen Texten. Diese sollten dem Prüfer bereits bekannt sein und sind bei der Bewertung zu berücksichtigen.

Anhang B kann als Vorlage zur Dokumentation und Protokollierung genutzt werden. Hierzu stehen die letzten zwei Spalten für die Anmerkungen des Prüfers (siehe Kapitel 5.2) sowie das Prüfergebnis (siehe Tabelle 13) zur Verfügung.

Abkürzungsverzeichnis

Tabelle 15: Abkürzungsverzeichnis

API	Application Programming Interface (Anwendungs-/Programmierschnittstelle)
App	Applikation
A.*	Assumption (Annahme)
BaFin	Bundesanstalt für Finanzdienstleistungsaufsicht
BSI	Bundesamt für Sicherheit in der Informationstechnik
CCEM	Common Criteria Evaluation Methodology
DORA	Digital Operational Resilience Act
GPS	Global Positioning System
HTML5	Hypertext Markup Language 5
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
iOS	Betriebssystem des Unternehmens Apple für mobile Geräte
IPC	Interprozess Kommunikation
O.*	Objective (Prüfaspekt)
OSP.*	Organizational Security Policies (Organisatorische Sicherheitspolitiken)
PSD2	Payment Services Directive 2
SDK	Software Development Kit
SSID	Service Set Identifier
T.*	Threat (Bedrohung)
TR	Technische Richtlinie
TLS	Transport Layer Security
URL	Uniform Resource Locator
WiFi	Wireless Fidelity
XML	Extensible Markup Language

Literaturverzeichnis

[BSI200-3]

Bundesamt für Sicherheit in der Informationstechnik, „BSI-Standard 200-3 Risikoanalyse auf der Basis von IT-Grundschutz“, Version 1.0, verfügbar unter <https://www.bsi.bund.de/dok/10027822>

[ISO27005]

BS ISO/IEC 27005:2011, Information technology - Security techniques – Information security risk management

[KCC-C5]

Bundesamt für Sicherheit in der Informationstechnik, „Kriterienkatalog Cloud Computing“, Version 2026, verfügbar unter <https://www.bsi.bund.de/dok/7685384>

[NIST80057]

National Institute of Standards and Technology, „Recommendation for Key Management“, Revision 5, verfügbar unter <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>

[PSD2]

<https://www.bundesbank.de/de/aufgaben/unbarer-zahlungsverkehr/psd2/>

[DORA]

<https://www.bundesbank.de/de/service/meldewesen/bankenaufsicht/europaeisches-meldewesen/digital-operational-resilience-act-dora--951046>

[TR02102-1]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen“, Version 2026-01, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.html>

[TR02102-2]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen Teil 2 – Verwendung von Transport Layer Security (TLS)“, Version 2026-01, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102-2.html>

[TR03107-1]

Bundesamt für Sicherheit in der Informationstechnik, „Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1“, Version 1.1.1, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.html>

[TR03174-1]

Bundesamt für Sicherheit in der Informationstechnik, „Sichere Anwendungen im Finanzwesen Teil 1: Mobile Anwendungen“, Version 4.0

[TR03174-3]

Bundesamt für Sicherheit in der Informationstechnik, „Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“, Version 4.0